

TP CYBERSECURITE — BTS SIO SISR

Campagne de Phishing avec GoPhish

Simulation d'attaque — Analyse — Sensibilisation

VM Linux • GoPhish • SMTP • Cybersecurite

BTS SIO — SISR

2e Annee

Rayan LACHEHEB

Centre ORT Montreuil Daniel Mayer

N° Candidat : 090773113GK

Annee scolaire 2024 — 2025

Sommaire

1.	Installation de GoPhish	3
2.	Configuration de base	3
3.	Lancer la campagne de phishing	5
4.	Analyse des resultats	8
5.	Sensibilisation et contre-mesures	9

Etape 1 : Installation de GoPhish

GoPhish est un framework open-source de simulation de phishing. Il s'installe sur une machine Linux et expose une interface web d'administration sur le port 3333 (HTTPS).

Telecharger GoPhish

```
wget https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-linux-64bit.zip
```

Decompresser

```
unzip gophish-v0.12.1-linux-64bit.zip -d gophish/
```

Rendre executable

```
chmod +x gophish/gophish
```

Lancer GoPhish

```
cd gophish && sudo ./gophish
```

Interface admin : <https://localhost:3333> — Login par défaut : admin / gophish (à changer immédiatement)

Etape 2 : Configuration de base

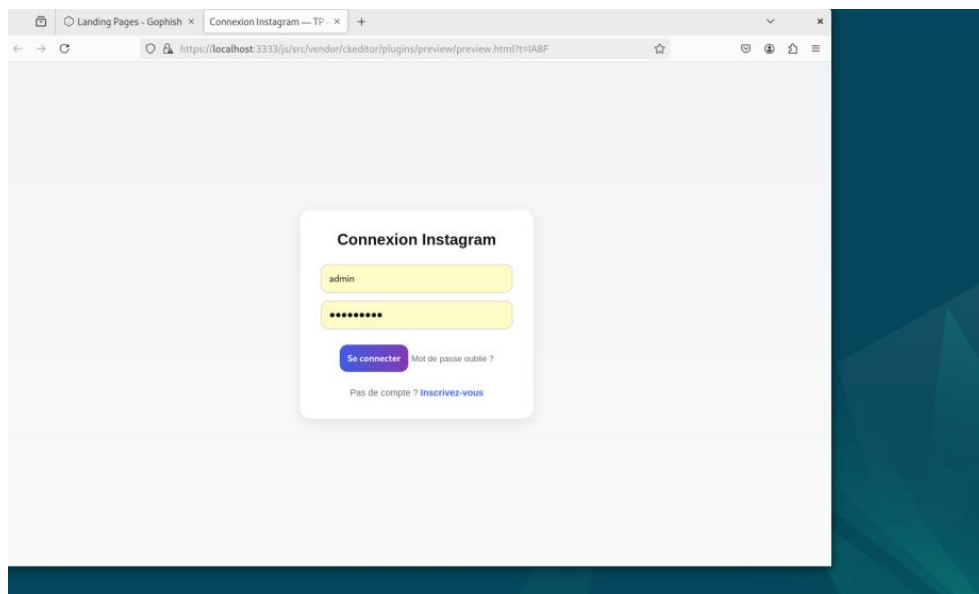
2.1 Créer un groupe d'utilisateurs cibles

Nous avons cree des boites mail de test pour simuler les destinataires de la campagne :

Role	Adresse email
Boite d'envoi (phishing)	instagram.office.mdp@gmail.com
Cible de test N°1	testphishing1cyber@gmail.com
Cible de test N°2	testphishing2cyber@gmail.com

2.2 Créer une landing page (page de destination)

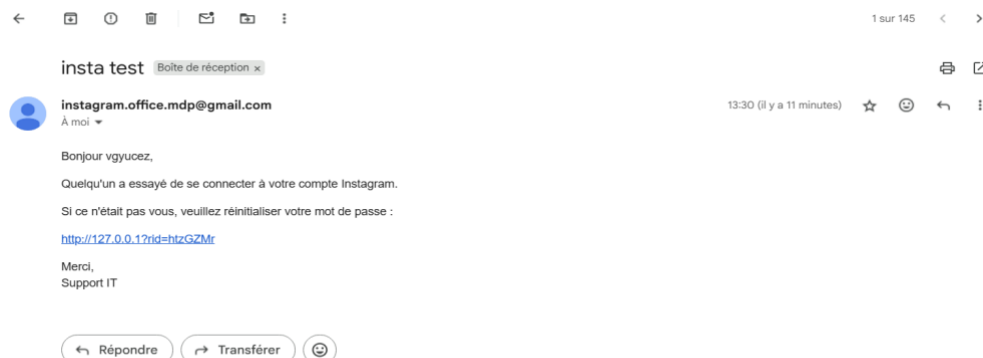
Creation d'une landing page HTML imitant la page de connexion Instagram pour intercepter les identifiants saisis :



Capture — Landing page imitant la connexion Instagram dans GoPhish

2.3 Créer le courriel de phishing

Le courriel envoye aux cibles imite une notification de securite Instagram avec un lien vers la landing page :



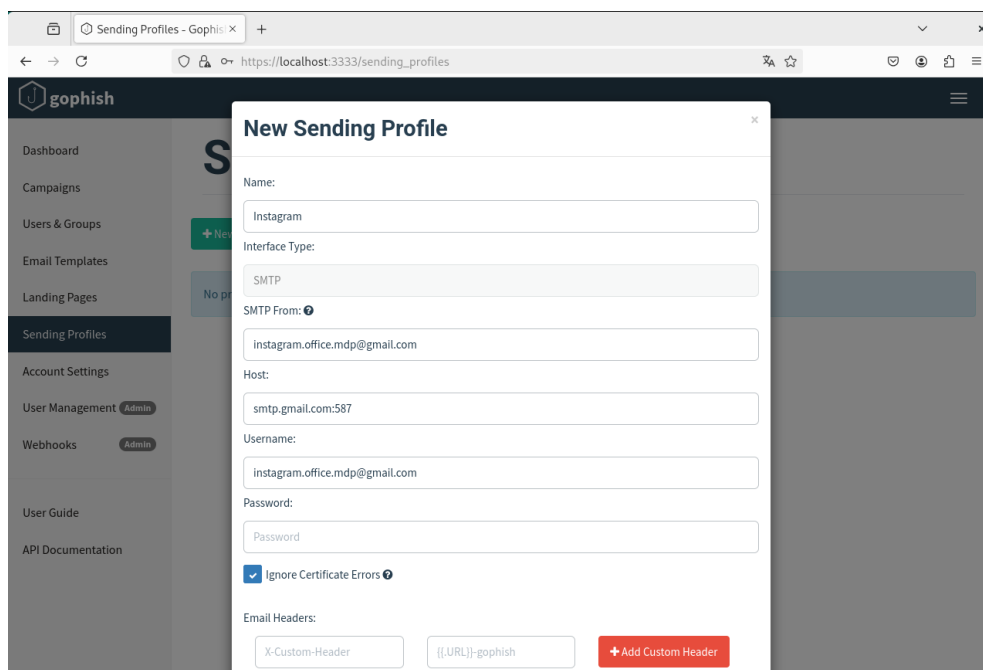
Capture — Exemple du courriel de phishing reçu par la cible

Etape 3 : Lancer la campagne de phishing

3.1 Configurer le profil d'envoi (Sending Profile)

Le profil d'envoi configure le serveur SMTP pour l'envoi des emails via Gmail avec un mot de passe d'application :

Parametre	Valeur
Name	Instagram
Interface Type	SMTP
SMTP From	instagram.office.mdp@gmail.com
Host	smtp.gmail.com:587
Username	instagram.office.mdp@gmail.com
Password	Mot de passe d'application Google (16 car.)



Capture — Formulaire de configuration du Sending Profile dans GoPhish

3.2 Generer un mot de passe d'application Google

Pour utiliser Gmail comme SMTP, il faut creer un mot de passe d'application dans les parametres de securite Google :

- 1 Aller dans Compte Google > Securite > "Mots de passe des applications"
- 2 Activer la verification en 2 etapes (obligatoire)
- 3 Saisir le nom de l'application (ex: Gophish)
- 4 Google genere un mot de passe de 16 caracteres a copier dans GoPhish

[←](#) Mots de passe des applications

Les mots de passe d'application vous permettent de vous connecter à votre compte Google sur des applis et des services plus anciens, non compatibles avec les normes de sécurité les plus récentes.

Les mots de passe d'application sont moins sécurisés que les applis et services à jour qui utilisent les normes de sécurité les plus récentes. Avant de créer un mot de passe d'application, vous devez vérifier si votre appli en a besoin pour établir la connexion.

[En savoir plus](#)

Vos mots de passe d'application

Gophish	Date de création : 09:27, dernière utilisation : 09:28	
---------	--	---

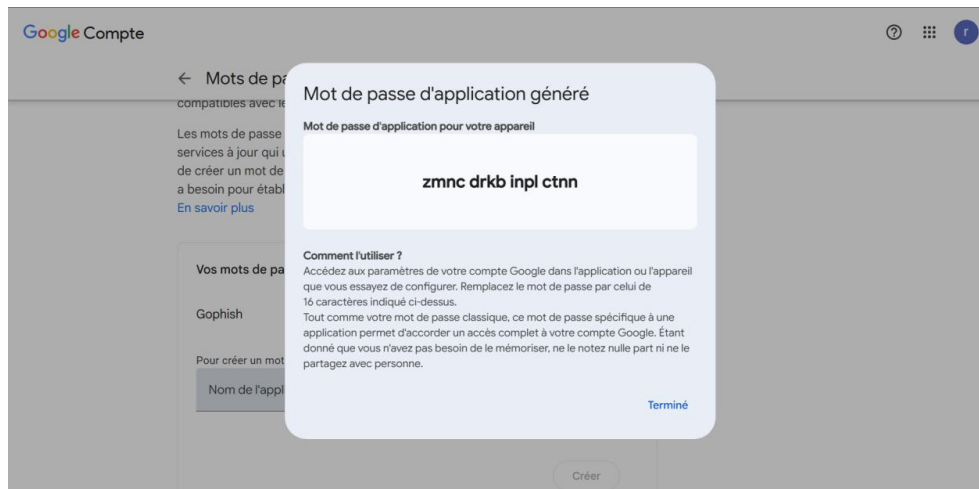
Pour créer un mot de passe spécifique à une appli, indiquez son nom ci-dessous.

Capture — Mot de passe d'application genere par Google

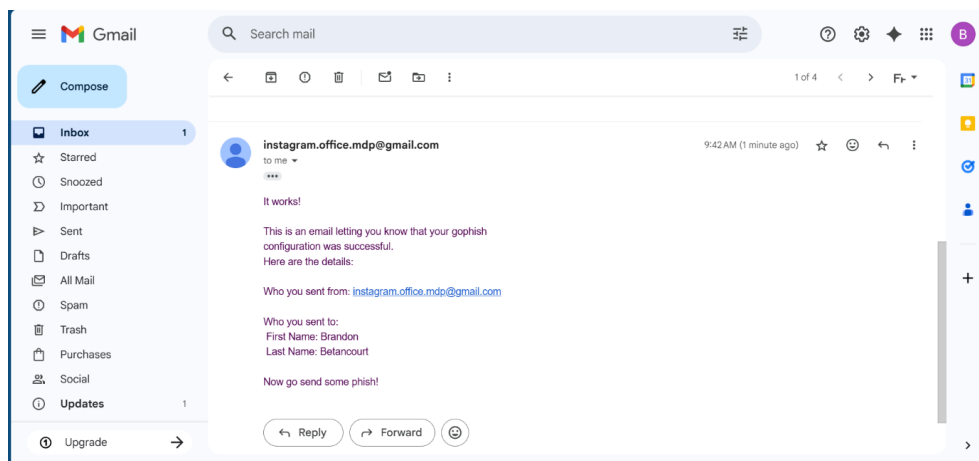
3.3

Verifier l'envoi et demarrer la campagne

Un test d'envoi est effectuée avant de lancer la campagne. GoPhish affiche "Email Sent !" si tout est correct :



Capture — Confirmation "Email Sent!" et reception dans Gmail

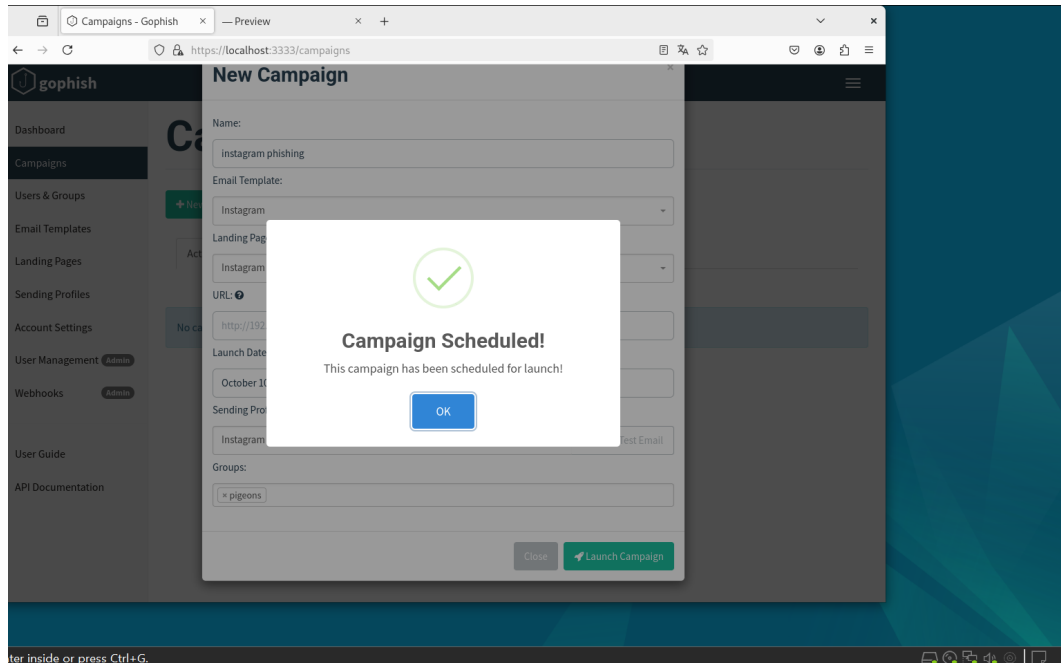


Capture — Campagne planifiée "Campaign Scheduled!" dans GoPhish

3.4

Tableau de bord : resultats en temps reel

Le tableau de bord GoPhish affiche : emails envoyes, ouverts, clics sur le lien et soumissions d'identifiants :



Capture — Dashboard GoPhish : resultats de la campagne "Instagram phishing"

Etape 4 : Analyse des resultats

Observation des comportements

L'analyse de la campagne met en evidence les comportements suivants :

5

1

1

0

Identifiants saisis

Interpretation

Le fait qu'un utilisateur ait clique sur le lien montre que le message presentait des elements credibles. Aucun identifiant n'a ete saisi, ce qui traduit une vigilance globale satisfaisante. Cela souligne la necessite de poursuivre les actions de sensibilisation.

Signaux d'alerte identifies lors du debriefing



Adresse expéditeur suspecte — L'adresse ne correspondait pas au domaine officiel Instagram



URL non conforme — Le lien pointait vers 127.0.0.1 (localhost) et non vers instagram.com



Urgence artificielle — Le message incitait a agir rapidement (reinitialisation de mot de passe)



Formulation generique — Les emails officiels ne s'adressent pas de facon aussi vague

Etape 5 : Sensibilisation et contre-mesures

Pourquoi le phishing fonctionne encore ?

- Les messages frauduleux imitent parfaitement les communications legittimes.
- Les utilisateurs soumis a la pression temporelle reduisent leur vigilance.
- Le manque de formation continue entraine une baisse de la detection.
- Le facteur humain reste la principale vulnerabilite des SI.

Contre-mesures techniques

Mesure	Description
Filtres antispam/antivirus	Bloquer les courriels frauduleux avant reception
Filtrage DNS et URL	Bloquer l'accès aux sites de phishing connus
Authentification MFA	Reduire l'impact d'un vol de mot de passe
Surveillance journaux	Alertes en cas de comportements anormaux
SPF / DKIM / DMARC	Authentifier les emails sortants, eviter l'usurpation

Bonnes pratiques recommandees

- OK** Verifier l'adresse de l'expediteur et l'orthographe du domaine.
- OK** Ne jamais cliquer sur un lien ou ouvrir une piece jointe douteuse.
- OK** Signaler les tentatives de phishing via le mecanisme interne.
- OK** Changer son mot de passe immediatement en cas de clic suspect.
- OK** Se mefier des messages evoquant urgence, menace ou recompense.
- OK** Participer aux sessions de sensibilisation proposees.